UNIVERSITY OF LONDON

BSc EXAMINATION 2022

For Internal Students of
Royal Holloway

DO NOT TURN OVER UNTIL TOLD TO BEGIN

IY3660: Applications of Cryptography

IY3660R: Applications of Cryptography – PAPER FOR FIRST SITS/RESIT CANDIDATES

Time Allowed: **TWO hours**

Answer THREE questions

No credit will be given for attempting any further questions
CS/MT/EC calculators are permitted

©Royal Holloway, University of London 2022

Important Copyright Notice
This exam paper has been made available in electronic form
strictly for the educational benefit of current Royal Holloway students
on the course of study in question.
No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 1

(a) Modern stream ciphers are based on a *keystream generator* algorithm. The keystream generator $\mathcal{G}$ takes as input a secret key K and an initialisation vector IV, and generates as output a stream of bits $k_1, k_2, \ldots$ called the *keystream*.

i. What property must the output bitstreams produced by $\mathcal{G}$ satisfy, in order for the keystream generator to be used as a basis for a secure stream cipher? [1 mark]

ii. Let E be a stream cipher based on a keystream generator $\mathcal{G}$. If P is a plaintext message, considered as an m-bit string, describe the operation of encryption of P with the stream cipher E under key K and initialisation vector IV. [2 marks]

iii. Denote the resulting ciphertext by C. Describe the operation of the decryption of C under the same key K and initialisation vector IV? [2 marks]

iv. Suppose two plaintexts P and $\overline{P}$, of same bit length m, are encrypted by the stream cipher under the **same** secret key K and initialisation vector IV. Explain why an adversary who observes the corresponding ciphertexts C and $\overline{C}$, and is aware of this operational fact, may be able to learn information about the plaintexts. [3 marks]

(b) What is the main difference between a block cipher and a stream cipher? [2 marks]

(c) Explain why block ciphers are usually used in modes of operation. [1 mark]

(d) The *Cipher Block Chaining* (CBC) mode of operation takes a sequence of plaintext blocks $P_1, P_2, \ldots, P_t$ and outputs ciphertext blocks $C_0, C_1, C_2, \ldots, C_t$, where $C_0 = IV$ is the initialisation vector and where $C_i = E_K(C_{i-1} \oplus P_i)$ for each $1 \leq i \leq t$. Here $E_K(\cdot)$ denotes the block cipher encryption operation with key K.

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

i. Draw a diagram to illustrate the encryption algorithm of this mode. [2 marks]

ii. Write down equations, similar to those above for encryption, that describe the decryption operation for the CBC mode. [2 marks]

iii. What are the properties that the initialisation vector IV must satisfy for secure operation of the CBC mode? [1 mark]

(e) Explain what is meant by the "error propagation properties" of a block cipher mode of operation. Describe the error propagation in the (i) ECB mode, (ii) CBC mode and (iii) CTR mode? [4 marks]

(f) Let E be a block cipher operating on 4-bit blocks. Let K be a key, such that encryption with E under K is given by the table below:

$0000 \mapsto 1100$	$0100 \mapsto 1001$	$1000 \mapsto 0011$	$1100 \mapsto 0100$
$0001 \mapsto 0101$	$0101 \mapsto 0000$	$1001 \mapsto 1110$	$1101 \mapsto 0111$
$0010 \mapsto 0110$	$0110 \mapsto 1010$	$1010 \mapsto 1111$	$1110 \mapsto 0001$
$0011 \mapsto 1011$	$0111 \mapsto 1101$	$1011 \mapsto 1000$	$1111 \mapsto 0010$

For example, $E_K(0000) = 1100$ and $E_K(0100) = 1001$.
Likewise, the decryption of 0010 is given by $D_K(0010) = E_K^{-1}(0010) = 1111$.

Alice and Eve have engaged in a commercial transaction, which will require that Alice sends a payment instruction to their bank, to transfer the transaction amount of 9,000 to Eve's account. The instruction message is produced by the bank app in Alice's mobile, which uses the block cipher E under a fixed secret key K, as defined in the table above. This key is shared with the bank server. Payment instruction messages between the app and the bank have the following structure.

- The app generates payment instructions as 14-bit messages, for payments of multiples of a thousand pounds, to the limit of 15,000.
- The first 4 bits of the message correspond to the binary representation of the amount in thousands of pounds to be transferred, e.g. a message with the instruction to transfer 1,000 will have the first four bits as 0001;

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

a transfer of 5,000 will have the first four bits as `0101`; a payment instruction to transfer the maximum amount of 15,000 will have the first four bits as `1111`.

- The remaining 10 bits of the message contain account information for the payee and beneficiary, using a proprietary format.

Following the transaction between Alice and Eve, on Alice's input the bank app in her mobile generated the following payment instruction message:

$$M = \texttt{1001 0010 1100 10}.$$

Note that the first four bits `1001` indicate that the bank should transfer 9,000 to the beneficiary. The remaining bits `0010 1100 10` encode the account information for Alice and Eve. The app then encrypts this 14-bit message with E under key K, and sends the ciphertext to the bank.

i. Assume that the app uses the block cipher E in **CTR mode** for encryption. As counter, it uses the convention $ctr_0 = \texttt{0000}$, $ctr_1 = \texttt{0001}$, $ctr_2 = \texttt{0010}$, $ctr_3 = \texttt{0011}$, $ctr_4 = \texttt{0100}$, etc.
Compute the ciphertext produced by the app, on encrypting the payment instruction message M above, with E_K in CTR mode. [4 marks]

ii. Assume that Eve intercepts the ciphertext. Eve **is aware of the message structure and of the encryption scheme used in the app, but** *not* **the secret key** K. **She is also obviously aware of the amount in the payment instruction** (namely, 9,000). Explain what modification Eve should do to the ciphertext before relaying it to the bank, so that on receipt and decryption by the server, the bank will transfer the maximum amount of 15,000 to her account? [2 marks]

iii. Now assume that the app uses the block cipher E in **CBC mode** for encryption. For messages that require padding, it uses a simple padding scheme: it (always) adds a single `1` bit at the end of the message; then, it adds to the resulting string as many zero bits `0` as are needed to fill up a complete 4-bit block. Recall that CBC mode makes use of an

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

initialisation vector, which by convention is considered as the block C_0 of the ciphertext (refer to this question's item (d)). For the encryption of this payment instruction message M, the app generates at random the initialisation vector $IV = \texttt{0010}$.

Compute the ciphertext produced by the app, on encrypting the payment instruction message M above under the key K and initialisation IV in CBC mode. [5 marks]

iv. Assume again that Eve intercepts the ciphertext computed by the app. Moreover, like in item (ii) above, she is also aware of the message structure, the amount in the payment instruction (9,000), and the encryption scheme used in the app, but *not* the secret key K. Explain what modification Eve should do to the ciphertext before relaying it to the bank, so that on receipt and decryption by the server, the bank will transfer the maximum amount of 15,000 to her account? [2 marks]

v. For both cases above, what other cryptographic mechanism – in addition to CTR/CBC encryption – would you suggest that the app should use to protect its communication with the bank against the sort of attacks performed by Eve? [1 mark]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 2

(a) An *Authenticated Encryption (AE) scheme* consists of a triple of algorithms, (`KGen`, `Enc`, `Dec`). Describe the function of each of these algorithms and explain what is meant by the *correctness* of an AE scheme. [4 marks]

(b) Security for AE schemes is defined in terms of the combination of two security notions: *indistinguishability under chosen plaintext attacks* (IND-CPA security), and *integrity of ciphertexts* (INT-CTXT security).
Give informal descriptions of these two notions, using diagrams to illustrate your answer if you wish. For both notions, state what it means for an AE scheme to be secure. [8 marks]

(c) Answer the following questions about cryptographic hash functions.

i. Define the concept of an n-bit hash function. [2 marks]

ii. Define the three main security properties that a cryptographic hash function should possess. [3 marks]

iii. Provide **two** different applications of cryptographic hash functions, and explain how they are used in these two applications. Moreover, for each of the two applications, give the security properties of hash functions (as you defined in item (c).ii above) which the application relies on. [6 marks]

(d) Let $f : \{0,1\}^{n+k} \rightarrow \{0,1\}^n$ be a *compression function*, taking $(n+k)$-bit inputs, and producing n-bit outputs.

i. Describe how one can construct a hash function H based on f and the *Merkle-Damgård* iterated hashing technique. If you wish, you may use a diagram in your answer. [3 marks]

ii. How long is the output of the hash function H? Why does the iterated hashing construction of H require a padding scheme? [2 marks]

iii. What is the relation between the collision resistance property of the compression function f and of the hash function H? [1 mark]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

(e) Describe the *birthday paradox* and explain its application to generic collision finding attacks on hash functions. In your answer, state the time and memory complexity of the attack in terms of n (the bit length of the hash function output), and explain its implications for the choice of n if the application deploying the hash function aims for a 128-bit security level. [5 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 3

(a) Describe the main security goals of the TLS Handshake Protocol. [3 marks]

(b) The TLS Handshake Protocol has *ciphersuite negotiation* as a feature. Explain what this feature does, why it is important, and the mechanism by which it is performed in TLS. [4 marks]

(c) The TLS Handshake Protocol provides a number of different mechanisms for establishing keys. One of them uses RSA-based public-key encryption, which until recently was the most popular choice.

i. Describe this specific mechanism, focussing in your answer on the message exchanges that take place between the protocol participants to negotiate and then use this mechanism. If you wish, you may use a diagram to illustrate your answer. [6 marks]

ii. The use of RSA-based public key encryption in TLS, in combination with the `ServerFinished` message, also provides the basis of authentication of the server to the client in the TLS Handshake Protocol. Explain why. [3 marks]

iii. The more recent TLS 1.3 standard no longer supports RSA-based key establishment due to its lack of *forward security* (or *secrecy*). Explain why RSA-based key establishment does not offer forward secrecy, and why the lack of forward secrecy may be a considered a vulnerability in key establishment protocols. [2 marks]

(d) The TLS Handshake Protocol also supports the *ephemeral* Diffie-Hellman Key Exchange (DHKE) protocol, which *does* provide forward secrecy. The protocol's parameters (in the setting of integers modulo a prime p) are: the primes p, q such that q divides $p-1$, and a value $g > 1$ such that $g^q = 1 \bmod p$. In TLS, these parameters are selected by the server and sent to the client. Assuming both parties now have the p, q, g values, describe the ephemeral Diffie-Hellman Key Exchange protocol. [5 marks]

(e) What is the computational problem underlying the security of the DHKE protocol? How does it relate to the Discrete Logarithm Problem (DLP) in the

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

given setting? [2 marks]

(f) Discuss the security weaknesses of ephemeral DHKE in the situation where the adversary is an active party. [3 marks]

(g) How does the TLS Handshake Protocol protect against the weaknesses identified in your answer to item 3.(f) above? [2 marks]

(h) Discuss the threats (if any) that scalable and reliable quantum computers would pose to the security of current versions of the two TLS subprotocols: the TLS Handshake Protocol and the TLS Record Protocol. [4 marks]

No further copying, distribution or publication of this exam paper is permitted.
By printing or downloading this exam paper, you are consenting to these restrictions.

Question 4

The People's Republic of Ruritania (PRR) has decided to take a great leap forward into the electronic age, by equipping its citizens with secure communications facilities.

In the planned deployment, each citizen of the PRR will be issued with a smart-card that stores a long-term Diffie-Hellman private key x and a long-term Diffie-Hellman public key $g^x \bmod p$ for that citizen. Here $p = kq + 1$, and g generates G_q, a cyclic group of prime order q in the set of integers modulo the prime p; that is, $G_q = \{g^0 = 1, g^1, g^2, \ldots, g^{q-1}\}$. All smart-cards will use the same parameters (p, q, g).

When given another citizen's public key $g^y \bmod p$ as input, the smart-card will use its stored private key to compute and output the shared Diffie-Hellman key $K = g^{xy} \bmod p$. It is planned that this shared key will be used as the key in a symmetric encryption scheme to protect messages sent between citizens. To enable this, each citizen will be given a smart-card reader that plugs into the citizen's personal laptop or desktop computer, enabling that computer to interact with smart-cards. All encryption and decryption using the symmetric scheme will be performed using a secure messaging application that will be installed on the citizen's personal computer. That computer will also be used to send and receive messages over the Ruritanian Internet to and from other citizens of the PRR. Because all the long-term keys are stored on smart-cards, and because the people of Ruritania can all be trusted to look after their cards properly, the system's designers decided not to bother with authentication of the public keys.

Experts at Royal Holloway were commissioned by the Ruritanian government to perform a security analysis of the **cryptographic aspects** of the proposed system. However, they are very busy due to their heavy workload, and decided instead to delegate the work to you. You are therefore asked to prepare an initial report that they can give to the government. **Your task is to produce that report.**

In your report, you may choose to focus on the following topics: appropriate selection of the system-wide parameters (p, q, g); the lifecycle of keys in the system;

potential for attacks on the system and for system abuse; the wisdom of dispensing with authentication of public keys in the system; selection of a suitable symmetric encryption scheme; alternative cryptographic solutions. Further *cryptographic* aspects of the proposed system may be addressed in your report, and will be credited as appropriate. [34 marks]

END